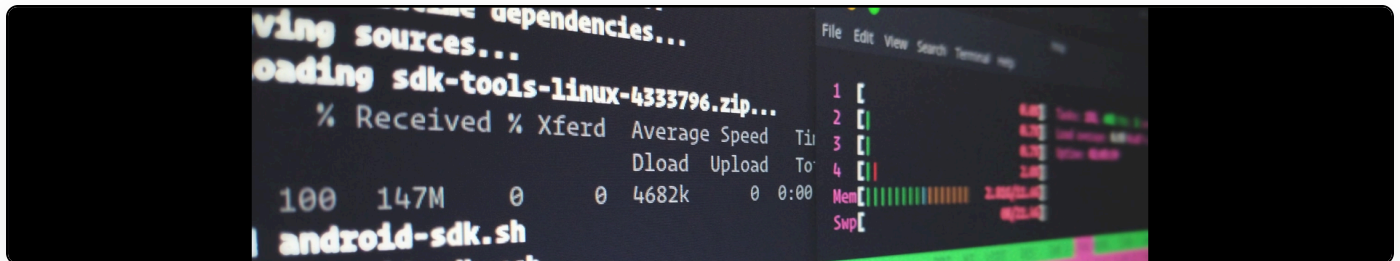


Some evil stuff from sla.ckers

Cite as: Martin Paul Eve, "Some evil stuff from sla.ckers", *eve.gd: Martin Paul Eve*, July 05, 2007, <https://doi.org/10.59348/wwj37-v4229>.



There's such a wealth of new XSS vectors coming out of the work on phpid's that I couldn't resist sharing a few of the tastier morsels here. The original thread is over at [sla.ckers](#) if you want to read it there!

SirDarckCat brings us:

```
http://domain.org/?
test=a%3D0%7C%7Ceval%7C%7C0%3Bb%3D0%7C%7Cunescape%7C%7C0%3Ba%28b%28location%29%29#%0d%0
aalert%28%22xss%22%29%3B
```

which corresponds to

```
a=0||eval||0;b=0||unescape||0;a(b(location))
```

So how the heck is this vector working? The statement formed at the end of the line reads:
eval(unescape(location))

Eval executes whatever is inside it; unescape removes url encoded chars; but this means that the LOCATION is being evaluated. ma1 explains how this vector works (hint, it is to do with the newline chars in the url!)

http: - parsed as a valid ECMA262 label

//host:port/path/...#...[newline] - C++ style comment opener

yourPayloadHere() - :D

Now that is evil!

A further vector along the same lines which was originally provided by SirDarckCat and further obfuscated by myself (so modest I know - well, I thought I'd better contribute something original to this post!) is this little piece of trickery:

```
a=0||'ev'+al',b=0||1[a]('loca'+'tion.hash'),c=0||'sub'+str',1[a](b[c](1));
```

The workings require a little explanation...

a is loaded with the eval statement that has been concatenated from 2 parts. b is loaded with an eval [a] of location.hash, again formed from 2 joined strings. c is loaded with substr and then all 3 are pieced together to give: eval(location.hash.substr(1)) - so anything after the fragment identifier in the url will be executed as a payload.

Seriously interesting stuff guys - and keeping us busy over at the IDS!